Case 02 · יומן ההחלטות (ADR log): Private Exposure Registry

מסמך נלווה לפרק הארכיטקטורה. כל רשומה בפורמט ADR (Architecture Decision Record): הקשר, החלטה, חלופות שנשקלו ונדחו, והשלכות.

איך קוראים את היומן

כשאדריכל מחליט שקיר מסוים נושא את הבית, הוא כותב למה, כדי שמי שיבוא אחריו לא יפיל אותו בשיפוץ. ADR עושה את אותו הדבר בתוכנה: רשומה קצרה שמתעדת החלטה אחת, את מה שהוביל אליה, ואת מה שוויתרנו עליו. רשומה לא נמחקת. אם החלטה משתנה, נכתבת רשומה חדשה שמחליפה את הישנה.

במערכת הזו יש עיקרון אחד שחוזר בכל הרשומות: אף אחד לא סומך על אף אחד. כל החלטה בודקת מה קורה אם אחד המשתתפים, רשות, שרת או קרן, מתנהג לא כמו שצריך.

מספר	ההחלטה	סטטוס
ADR-001	היומן הוא מקור האמת, לא מסד נתונים	התקבלה
ADR-002	מסלול נפרד לדיווחים ומסלול נפרד לשאלות (CQRS)	התקבלה
ADR-003	תור עמיד למעטפות, במקום שליחה ישירה	התקבלה
ADR-004	שינוי בקטלוג או בתקציב דורש שלוש חתימות	התקבלה
ADR-005	אסימון עיוור אחד לכל גוף לתקופה	התקבלה
ADR-006	סף של חמש קרנות לתא, ובדיקת הפרשים בזמן התכנון	התקבלה
ADR-007	אימות כל סכום מול ההתחייבויות, וחיפוש בינארי לאיתור שרת משבש	התקבלה
ADR-008	מחיקת החלקים אחרי 90 יום	התקבלה

ADR-001: היומן הוא מקור האמת

- **סטטוס:** התקבלה
- **רכיבים:** יומן השקיפות, האוסף והמאמת, שער השאלות, הביקורת המדגמית

הקשר

כל טענה במרשם, מי דיווח, מה נפתח ואיזו שאלה נשאלה, צריכה להיות ניתנת לבדיקה בידי מי שלא סומך על אף רשות.

ההחלטה

יומן שקיפות מבוסס עץ Merkle הוא מקור האמת. כל רכיב כותב אליו לפני שהוא מאשר פעולה, וכל אחד יכול לקרוא ממנו. בכל יום מתפרסם שורש חתום על ידי שלוש הרשויות. את כל מצב הרגולטור אפשר לבנות מחדש מהיומן לבדו.

חלופות שנשקלו ונדחו

- **מסד נתונים רגיל אצל אחת הרשויות:** נדחה כי מי שמחזיק את המסד יכול לשנות היסטוריה בשקט, ושתי הרשויות האחרות צריכות לסמוך עליו.

השלכות

- **חיובי:** אי אפשר לשנות היסטוריה בלי שיתגלה, וכל טענה ניתנת לבדיקה.
- **שלילי:** היומן חייב להיות זמין תמיד, ולכן הוא משוכפל. שינוי במבנה של אירוע שכבר נכתב מסובך.

ADR-002: מסלול נפרד לדיווחים ומסלול נפרד לשאלות

- **סטטוס:** התקבלה
- **רכיבים:** השרת המוביל, האוסף והמאמת, שער השאלות, הדוחות

הקשר

רגולטורים שואלים שאלות, וקרנות מדווחות. אם שני הדברים עוברים באותו מסלול, תמיד יש סיכון ששאלה תיגע בדיווח בודד.

ההחלטה

שני מסלולים נפרדים (CQRS): מסלול הכתיבה מקבל דיווחים וצובר אותם לאצוות. מסלול הקריאה עונה רק מתוך סכומים מאומתים של אצוות סגורות.

חלופות שנשקלו ונדחו

- **מודל אחד לכתיבה ולקריאה:** פשוט יותר. נדחה כי ההפרדה היא חלק מהאבטחה: אין נתיב שבו שאלה של רגולטור נוגעת בדיווח בודד.

השלכות

- **חיובי:** מבנה שבו דליפה דרך שאלה פשוט לא אפשרית.
- **שלילי:** תשובה זמינה רק אחרי שאצווה נסגרה ואומתה.

ADR-003: תור עמיד למעטפות

- **סטטוס:** התקבלה
- **רכיבים:** השרת המוביל, שרתי העוזרים, אפליקציית המשתתף

הקשר

כל דיווח צריך שלוש מעטפות שיגיעו לשלושה שרתים בשלוש מדינות. אחד מהם יהיה לפעמים לא זמין, ובשיטה שבה שלושת החלקים נחוצים, מעטפה שאבדה היא דיווח שאבד.

ההחלטה

המוביל שומר את הדיווח ואת המעטפה לכל עוזר באותה פעולה (Transactional Outbox), ומעביר מהתור עד שהעוזר מאשר. המוביל לא יכול לפתוח את המעטפות של העוזרים, גם כשהן אצלו.

חלופות שנשקלו ונדחו

- **שליחה ישירה מהקרן לכל עוזר:** נדחה כי כל נפילה של עוזר הייתה מאבדת דיווחים, והקרנות היו צריכות לנהל ניסיונות חוזרים בעצמן.

השלכות

- **חיובי:** שום דיווח לא אובד כשעוזר נופל. הדוח מתעכב, אבל שלם.
- **שלילי:** העברה "בסופו של דבר" ולא מיידית, וייתכנו כפילויות שהעוזר חייב לזהות לפי מזהה הדיווח.

ADR-004: שינוי בקטלוג או בתקציב דורש שלוש חתימות

- **סטטוס:** התקבלה
- **רכיבים:** שער השאלות, יומן השקיפות

הקשר

הקטלוג קובע אילו שאלות מותר לשאול, ותקציב הפרטיות קובע כמה. מי שמשנה אותם יכול, בכוונה או בטעות, לחשוף קרן.

ההחלטה

כל שינוי בקטלוג או בתקציב נכנס לתוקף רק עם חתימות של שלוש הרשויות, ונרשם ביומן.

חלופות שנשקלו ונדחו

- **רשות אחת מאשרת:** מהיר. נדחה כי אז רשות אחת לבדה יכולה להוסיף שאלה שנועדה לחשוף משתתף, או להגדיל את התקציב בשקט.

השלכות

- **חיובי:** אף רשות לא יכולה לשנות את כללי המשחק לבד.
- **שלילי:** שינויים איטיים. אם רשות אחת לא מגיבה, אין שינוי. זה מכוון.

ADR-005: אסימון עיוור אחד לכל גוף לתקופה

- **סטטוס:** התקבלה
- **רכיבים:** שירות הזהות, אפליקציית המשתתף, השרת המוביל

הקשר

הסף של חמש קרנות לתא שווה משהו רק אם כל קרן היא גוף אמיתי. בלי זיהוי, תוקף יכול לרשום ארבע קרנות ריקות, לפתוח תא שיש בו קרן אחת, ולהחסיר את עצמו.

ההחלטה

שירות הזהות מאמת LEI מול המאגר העולמי ומול רשימת הגופים המפוקחים, ומנפיק אסימון עיוור אחד לגוף לתקופה. האסימון מוסתר לפני החתימה, כך שהשירות לא יכול לקשר אותו לדיווח.

חלופות שנשקלו ונדחו

- **זיהוי גלוי בכל דיווח:** נדחה כי אז השרתים יודעים מי דיווח מה, וכל הפיצול מאבד את הטעם.
- **בלי זיהוי בכלל:** נדחה בגלל התקפת הקרנות המזויפות.

השלכות

- **חיובי:** רק גופים אמיתיים נספרים, ואף שרת לא יודע מי הם.
- **שלילי:** תלות במאגר חיצוני. התחליף: רשימת הגופים שהרגולטור כבר מחזיק.

ADR-006: סף של חמש, ובדיקת הפרשים בזמן התכנון

- **סטטוס:** התקבלה
- **רכיבים:** שער השאלות

הקשר

גם תשובה מצרפית יכולה להסגיר משתתף: בתא עם שתי קרנות, כל אחת מחסירה את עצמה ומגלה את השנייה. ושתי שאלות קרובות, כמו "כל הענפים" ו"כל הענפים חוץ מאנרגיה", יכולות לחשוף ענף קטן דרך ההפרש.

ההחלטה

תא עם פחות מחמש קרנות לא נפתח. כל שאלה חדשה לקטלוג נבדקת אוטומטית מול כל שאלה קיימת, וזוג שההפרש ביניהם הוא תא קטן נדחה לפני שנשאל אפילו פעם אחת. על התשובות הציבוריות נוסף רעש מבוקר.

חלופות שנשקלו ונדחו

- **רעש בלבד, בלי סף:** נדחה כי בתא קטן מאוד הרעש הדרוש להגנה הורס את התשובה.
- **בדיקת הפרשים בזמן הפרסום:** נדחה כי אז התשובה הראשונה כבר יצאה.

השלכות

- **חיובי:** התקפת ההפרשים נחסמת בשלב התכנון.
- **שלילי:** חלק מהשאלות המעניינות לא נענות, וענפים קטנים נשארים חסומים.

ADR-007: אימות כל סכום, וחיפוש בינארי לאיתור שרת משבש

- **סטטוס:** התקבלה
- **רכיבים:** אפליקציית המשתתף, יומן השקיפות, האוסף והמאמת

הקשר

שרת שנפרץ יכול לשנות את הסכום החלקי שלו, והחיבור עדיין יעבוד: יצא מספר שגוי שנראה סביר.

ההחלטה

כל קרן נועלת את הנתונים שלה בהתחייבות הומומורפית ורושמת אותה ביומן לפני הפיצול. האוסף בודק שסכום החלקים שווה לסכום ההתחייבויות. אם לא, הוא מריץ חיפוש בינארי על חצאי האצווה, עד שהשרת המשבש מזוהה, עם הוכחה ביומן.

חלופות שנשקלו ונדחו

- **לסמוך על השרתים:** נדחה כי המערכת בנויה על ההנחה שאף אחד לא סומך על אף אחד.
- **הוכחות כבדות מכל שרת על כל פעולה:** נדחה בגלל העלות. הבדיקה המצרפית זולה, והחיפוש רץ רק כשיש בעיה.

השלכות

- **חיובי:** סכום שגוי לא נפתח לשום שאלה, והאשם מזוהה.
- **שלילי:** התחייבויות מגדילות את גודל הדיווח, והחיפוש מעכב את הדוח כשיש תקלה.

ADR-008: מחיקת החלקים אחרי 90 יום

- **סטטוס:** התקבלה
- **רכיבים:** מאגרי השרתים

הקשר

כל עוד החלקים שמורים בשלושת השרתים, פריצה עתידית לשלושתם יחד יכולה לשחזר דיווחים ישנים.

ההחלטה

כל שרת מוחק את החלקים שלו 90 יום אחרי שהאצווה נסגרה ואומתה. הסכומים המאומתים נשמרים אצל הרגולטור, היומן נשמר לתמיד, והסודות של כל קרן נשארים רק אצלה, לביקורת עתידית.

חלופות שנשקלו ונדחו

- **שמירה לתמיד:** נדחה בגלל הסיכון המצטבר.
- **מחיקה מיידית:** נדחה כי צריך זמן לבירור תקלות ולביקורת המדגמית.

השלכות

- **חיובי:** חלון החשיפה מוגבל בזמן.
- **שלילי:** אחרי 90 יום אי אפשר לחשב מחדש שאלה חדשה על נתונים ישנים. רק מה שכבר נפתח נשאר.